

ΣΥΜΜΟΡΦΩΣΗ ΕΠΙΧΕΙΡΗΣΙΑΚΗΣ ΔΙΑΔΙΚΑΣΙΑΣ ΑΚΤΙΝΟΔΙΑΓΝΩΣΤΙΚΟΥ ΤΜΗΜΑΤΟΣ ΝΟΣΟΚΟΜΕΙΟΥ ΜΕ ΤΟΝ ΚΑΝΟΝΙΣΜΟ ΝΙΣ 2

Αναγνώριση Υπηρεσιών & Συστημάτων

Πληροφοριακά δεδομένα:

- ηλεκτρονικό παραπεμπτικό ακτινολογικής εξέτασης
- ιατρική απεικόνιση και αντίγραφο στην βάση δεδομένων
- προσωπικά δεδομένα ασθενή
- αξιολόγηση εξέτασης από γιατρό
- CD με απεικόνιση εξέτασης
- αρχεία καταγραφής

Υλισμικοτεχνικά:

- Firewalls
- Switches
- Η/Υ
- Servers RIS/PACS
- MRI Scanner
- MRI Workstation

Λογισμικοτεχνικά:

- Εφαρμογές RIS/PACS
- Βάσεις δεδομένων
- Λογισμικό προστασίας

Ανθρώπινοι πόροι:

- Γραμματεία
- Ακτινολόγος τεχνικός
- Ακτινολόγος γιατρός
- Γενικός γιατρός
- ΥΑΣΠΕ

Κρίσιμα σημείου κινδύνου

- Η επικοινωνία με το εξωτερικό δίκτυο ενέχει κίνδυνο παραβίασης και διαρροής προσωπικών δεδομένων
- Θα πρέπει να γίνεται έλεγχος εξουσιοδότησης και αυθεντικοποίησης όταν γίνεται πρόσβαση στα προσωπικά και ιατρικά δεδομένα των ασθενών καθώς και παρακολούθηση στα αιτήματα πρόσβασης.
- Η πρόσβαση στο διαδίκτυο ή η επικοινωνία με εξωτερικές συσκευές και υπηρεσίες αποτελούν σημεία ευπάθειας και πρέπει να διαθέτουν επιπρόσθετη ασφάλεια.

Περιγραφή asset	Κατηγορία asset	Περιγραφή	Κρίσιμη Υπηρεσία	Πιθανή Ευπάθεια/Απειλή
Radiology Information System (RIS)	Πληροφοριακό Σύστημα	Αποθηκεύει τα προσωπικά και ιατρικά στοιχεία των ασθενών. Χρησιμοποιείται για τον προγραμματισμό των εξετάσεων και την διαχείριση των πληρωμών.	Ναι	Έλλειψη κρυπτογράφησης, outdated υποδομές, ενσωμάτωση με νέες τεχνολογίες χωρίς ασφάλεια.
Picture archiving and communication system (PACS)	Πληροφοριακό Σύστημα	Αποθηκεύει τις ιατρικές απεικονίσεις των ασθενών.	Ναι	Έλλειψη κρυπτογράφησης, έλλειψη αυθεντικοποίησης.
Firewall	Υλισμικοτεχνικό	Προστασία από μη εξουσιοδοτημένη πρόσβαση.	Ναι	Εκτέλεση απομακρυσμένου κώδικα, παράκαμψη αυθεντικοποίησης.
Switches	Υλισμικοτεχνικό	Συνδέει δικτυακά τις συσκευές του τοπικού δικτύου (H/Y υπολογιστές).	Ναι	Firmware με vulnerabilities, αδύναμη ασφάλεια πρόσβασης (default ή μη ισχυροί κωδικοί)
H/Y Ιατρών	Υλισμικοτεχνικό	Χρησιμοποιείται για πρόσβαση σε ιατρικές απεικονίσεις των ασθενών και παρέχει την αξιολόγηση τους.	Ναι	Παλιό λειτουργικό σύστημα, έλλειψη ασφαλής πρόσβασης.
H/Y Γραμματείας	Υλισμικοτεχνικό	Διαχειρίζεται τον χρονοπρογραμματισμό των εξετάσεων και έχει πρόσβαση στα προσωπικά δεδομένα των ασθενών.	Ναι	Παλιό λειτουργικό σύστημα, έλλειψη ασφαλής πρόσβασης, κίνδυνος phishing, ransomware.

Περιγραφή asset	Τεχνολογία/Πλατφόρμα	Αξιολόγηση Ασφάλεια	Πολιτική Αναφορών Ασφαλείας	Αξιολόγηση Κρίσιμου Κινδύνου
-----------------	----------------------	---------------------	-----------------------------	------------------------------

Radiology Information System (RIS)	Windows και Philips RIS	Ετήσια αξιολόγηση	Αναφορά εντός 48 ωρών	Κίνδυνος παραβίασης και διαρροής προσωπικών και ιατρικών δεδομένων. Κίνδυνος αλλοίωσης δεδομένων.
Picture archiving and communication system (PACS)	Windows server και Philips IntelliSpace PACS	Ετήσια αξιολόγηση	Αναφορά εντός 48 ωρών	Κίνδυνος παραβίασης και διαρροής προσωπικών και ιατρικών δεδομένων. Κίνδυνος αλλοίωσης δεδομένων.
Firewall	firmware v.2.5 έτους 2023	Ετήσια αξιολόγηση	Αναφορά εντός 12 ωρών	Κίνδυνος παράλειψης του firewall.
Switches	Cisco IOS	Ετήσια αξιολόγηση	Αναφορά εντός 24 ωρών	Κίνδυνος παραβίασης και διαρροής προσωπικών δεδομένων.
Η/Υ Ιατρών	Windows 10/11	Ετήσια αξιολόγηση	Αναφορά εντός 12 ωρών	Κίνδυνος παραβίασης και διαρροής προσωπικών δεδομένων.
Η/Υ Γραμματείας	Windows 10/11	Ετήσια αξιολόγηση	Αναφορά εντός 12 ωρών	Κίνδυνος παραβίασης και διαρροής προσωπικών δεδομένων.

Περιγραφή asset	Προτεινόμενη Πολιτική Ασφαλείας & Τεχνικό Μέτρο	Συσχέτιση με απαίτηση της NIS2
Radiology Information System (RIS)	Ενίσχυση κρυπτογράφησης, αυθεντικοποίησης, διατήρηση αντιγράφου ασφαλείας.	Άρθρο 21 και παρ.1 του άρθρου 24 (μέτρα για τη διαχείριση της ασφάλειας σε δίκτυα και πληροφοριακά συστήματα, κρυπτογράφηση, αυθεντικοποίηση, αντίγραφο ασφαλείας για ανάκαμψη)
Picture archiving and communication system (PACS)	Πολιτική Συστήματος: Ενίσχυση κρυπτογράφησης, αυθεντικοποίησης, διατήρηση αντιγράφου ασφαλείας.	Άρθρο 21 και παρ.1 του άρθρου 24 (μέτρα για τη διαχείριση της ασφάλειας σε δίκτυα και πληροφοριακά συστήματα, κρυπτογράφηση, αυθεντικοποίηση, αντίγραφο ασφαλείας για ανάκαμψη)
Firewall	Πολιτική συστήματος: Διαχείριση κανόνων πρόσβασης, χρήση logging, περιορισμός άγνωστων IP. Αντίδραση σε Επιθέσεις: Ενεργοποίηση αναφορών και άμεση ανάλυση για οποιαδήποτε παραβίαση των κανόνων.	Άρθρο 21 και παρ.1 του άρθρου 24 (μέτρα για τη διαχείριση της ασφάλειας σε δίκτυα και πληροφοριακά συστήματα, έλεγχος πρόσβασης, ανάλυση κινδύνου, διαχείριση περιστατικών) Άρθρο 16 (αναφορά περιστατικών)
Switches	Πολιτική Συστήματος: Συντήρηση μηχανήματος, μέτρα ασφαλείας αξιόπιστης λειτουργίας.	Άρθρο 21 και παρ.1 του άρθρου 24 (μέτρα για τη διαχείριση της ασφάλειας σε δίκτυα και πληροφοριακά συστήματα, συντήρηση και ασφάλεια)
H/Y Ιατρών	Πολιτική συστήματος: Ισχυρή ασφάλεια πρόσβασης και χρήση αυθεντικοποίησης, χρήση logging, κρυπτογράφηση προσωπικών δεδομένων, ενημέρωση λειτουργικού συστήματος, χρήση antivirus και firewall, παροχή εκπαίδευσης για αναγνώριση κινδύνου.	Άρθρο 21 και παρ.1 του άρθρου 24 (μέτρα για τη διαχείριση της ασφάλειας σε δίκτυα και πληροφοριακά συστήματα, κρυπτογράφηση, αυθεντικοποίηση) Άρθρο 20 (εκπαίδευση και κατάρτιση προσωπικού)
H/Y Γραμματείας	Πολιτική συστήματος: Ισχυρή ασφάλεια πρόσβασης και χρήση αυθεντικοποίησης, χρήση logging, κρυπτογράφηση προσωπικών δεδομένων, ενημέρωση λειτουργικού συστήματος, χρήση antivirus και firewall, παροχή εκπαίδευσης για αναγνώριση κινδύνου.	Άρθρο 21 και παρ.1 του άρθρου 24 (μέτρα για τη διαχείριση της ασφάλειας σε δίκτυα και πληροφοριακά συστήματα, κρυπτογράφηση, αυθεντικοποίηση) Άρθρο 20 (εκπαίδευση και κατάρτιση προσωπικού)